# SENTINEL

Secure development environment — one page

Local proof · stated boundaries · 2026

## EVERY CHANGE PASSES THREE CHECKPOINTS

### 01 · BEFORE THE COMMIT

The staged Git index, not the editor

BLOCKS

Any secret finding

Gitleaks 8.30.1

Deleting a secret in the working tree without staging it is still blocked.

### 02 · BEFORE THE MERGE

Five CI jobs on every push

BLOCKS

Tests · secrets in full history · config HIGH+ · fixable CRITICAL CVEs

GitHub Actions

Threshold set by who owns the finding, not by the raw count.

### 03 · BEFORE THE RUN

Hardened container, loopback only

BLOCKS

Root user · writable filesystem · capabilities

Docker

A control that is only written down has never stopped anyone.

## AND EVERY CHECKPOINT LEAVES A RECEIPT YOU CAN RE-RUN

### VERIFIED ON THIS MACHINE — 10 of 14 checks

- 26 automated tests passing, 0 skipped
- Synthetic secret blocked, repaired input allowed
- Staged-index bypass blocked, no commit created
- Container built, running hardened, health check green
- Local retrieval answers with cited sources, loopback only
- CI pipeline 5 of 5 jobs green, read back from GitHub

Every row above maps to a command that actually ran.

### NOT VERIFIED — REPORTED, NOT COUNTED — 4 of 14 checks

- Terraform init / validate — sandbox cannot read the directory
- Trivy configuration scan — same sandbox limit
- Trivy image scan — same sandbox limit
- Branch protection — a repository administrator action

These four are the honest gap. They are not counted as passing anywhere on this page.

CodeQL is skipped on a private repository without a Code Security licence — a licensing decision, and it is not counted as a pass either.

A tool that installed is not a check that passed.

## THE AI PART NEVER LEAVES THE MACHINE

**7 documents** — internal policy, English
> **69 chunks** — heading-aware split
> **768-d vectors** — local embedding model
> **hybrid retrieval** — BM25 + cosine, top 3
> **local model** — runs on this machine
> **cited answer** — or refuses to guess

**127.0.0.1 only — any non-loopback inference host is refused before a request is sent.**

Answers take 6–30 seconds on a CPU. That latency is the real price of keeping the data on the machine, and it is reported, not hidden.

Every number on this page comes from a command that actually ran.

github.com/jma-repo/secure-dev-platform